OWASP JUICE SHOP

Gobuster Directory Enumeration Findings Report

Local web-application discovery and HTTP response analysis

Target	OWASP Juice Shop running locally
Target URL	http://127.0.0.1:3000
Tool	Gobuster 3.8.2
Report date	23 October 2026

Scope note: This report documents only the local lab activity and recorded output available for review. It does not claim that the application is secure or that all possible paths were tested.

Executive Summary

A local OWASP Juice Shop instance was tested with Gobuster directory enumeration. The key technical complication was that the single-page application returned HTTP 200 for an obviously nonexistent path. The root page also reported a content length of 9,984 bytes. To reduce these false positives, the scan excluded responses with that length.

The controlled 200-entry wordlist scan completed successfully. It returned one result: /.well-known/security.txt with HTTP 200 and a response size of 483 bytes. No 403 or 404 paths were identified in this particular scan. This is a limited result, not proof that such paths do not exist.

Item	Recorded result	Interpretation
Scan list	200 entries	Small controlled wordlist
Completion	200 / 200 (100%)	Gobuster finished the list
Result found	/.well-known/security.txt	HTTP 200, 483 bytes
HTTP 403	Not found in this scan	No 403 result from tested words
HTTP 404	Not found in this scan	No 404 result from tested words
Fallback behavior	Unknown path returned 200	Potential false positives without filtering

Objective and Scope

Objective: use Gobuster with a wordlist to enumerate discoverable paths on the local OWASP Juice Shop target and review HTTP status-code behavior.

- Target: http://127.0.0.1:3000 (localhost only).
- Tool version recorded: Gobuster 3.8.2.
- Wordlists recorded: a 200-entry custom list at ~/juice-small.txt and SecLists common.txt at /usr/share/seclists/Discovery/Web-Content/common.txt.
- Status codes included in the controlled scan: 200, 301, 302, 403, and 404.
- Response length 9984 was excluded to suppress the known SPA fallback response.

This report does not include exploitation, credential testing, or claims about vulnerabilities beyond the observed enumeration behavior.

Lab Environment

The target was run inside a Kali Linux virtual machine. The recorded startup command was:

```
cd ~/juice-shop-packaged/juice-shop_20.3.0
node --max-old-space-size=1536 build/app.js
```

The expected startup log included: “Server listening on port 3000”. The following supplied screenshot shows the VirtualBox manager and Kali VM configuration. It is environmental context, not evidence of a successful Gobuster scan.

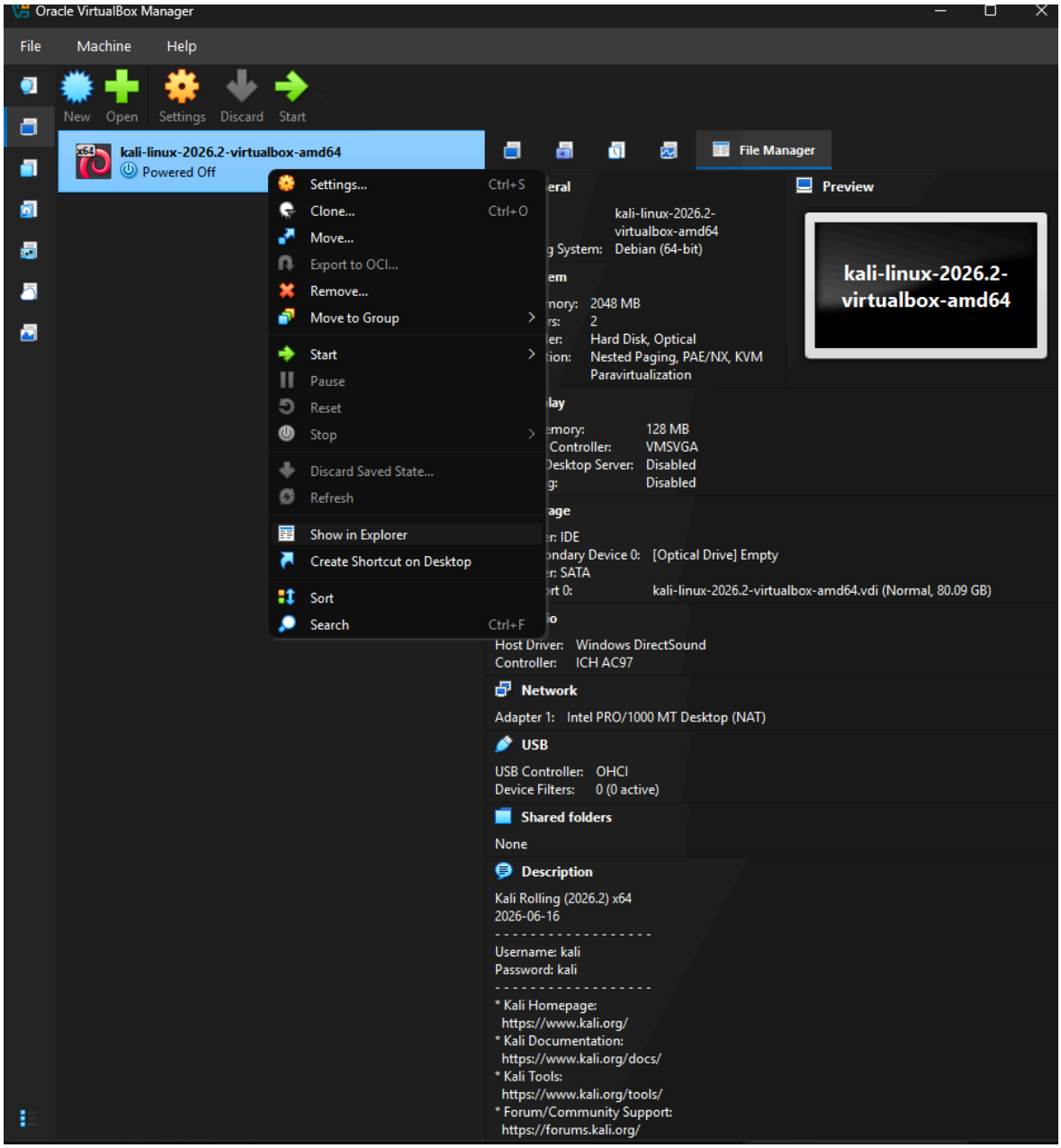
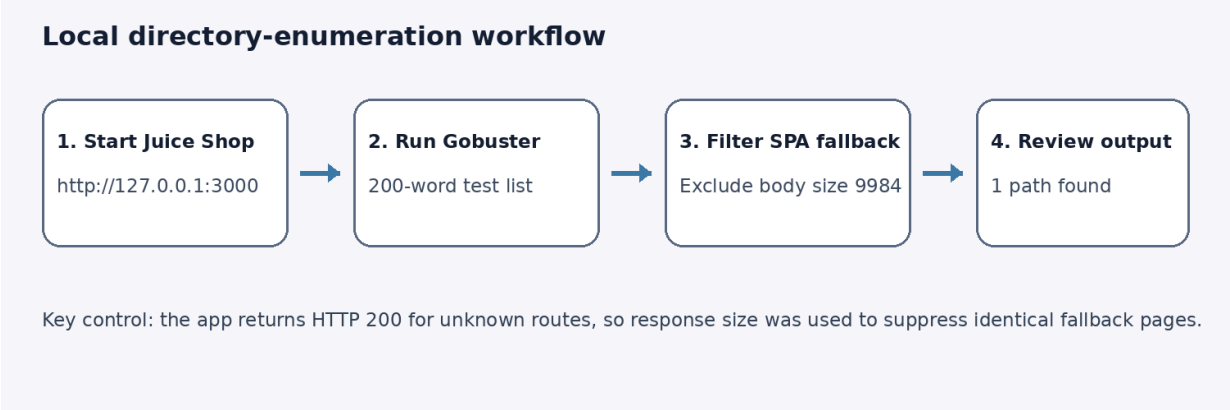


Figure 1. Supplied VirtualBox Manager screenshot showing the Kali Linux VM. The VM is shown powered off in this image.

Methodology



The test followed four steps:

1. Start the local Juice Shop application and verify that the root endpoint responds.
2. Run Gobuster directory enumeration against localhost using the selected wordlist.
3. Exclude responses with length 9984 because the application served a same-sized HTML fallback for a nonexistent route.
4. Review the output file and record returned paths, status codes, and response sizes.

Commands and Configuration

Controlled status-code scan (recorded command):

```
gobuster dir -u http://127.0.0.1:3000 \
  -w ~/juice-small.txt \
  -s 200,301,302,403,404 -b "" \
  --exclude-length 9984 -t 1 \
  --timeout 20s \
  -o ~/gobuster-status-check.txt
```

The scan used one worker thread and a 20-second timeout to keep the local test conservative. The output was saved to ~/gobuster-status-check.txt.

Findings

1 SPA fallback and false positives

The root endpoint returned HTTP 200 with Content-Length 9984. A test request to a deliberately nonexistent route also returned HTTP 200. Therefore, status code alone was not enough to distinguish real paths from the application's fallback page. Excluding response length 9984 reduced these false positives.

2 Enumerated path

Path	Status	Size	Observation
/.well-known/security.txt	200	483	Only result from the controlled 200-entry scan

3 Other results in previously saved output

Earlier saved result files recorded the following paths. These are listed separately because the precise run configuration and completion status for each file were not fully established in the available notes.

Path	Recorded status	Recorded size / note
.well-known/security.txt	200	483 bytes
Video	200	2,232,676 bytes
api	500	3,000 bytes
api/experiments	500	3,024 bytes
api/experiments/configurations	500	3,054 bytes
apis	500	3,002 bytes
assets	301	Redirect to /assets/
ftp	200	11,318 bytes

Interpretation caution: HTTP 500 entries indicate server errors for those requests, but their cause was not established. The /ftp response was also associated with a curl incomplete-response warning in one manual check. These observations should be investigated separately before drawing security conclusions.

Evidence

Figure 2 is a formatted transcript reconstructed from the recorded command and output. It is not a literal screenshot of the terminal. The original terminal screenshot files mentioned in the lab notes were not available as attachments in the workspace used to create this report.

```
RECORDED TERMINAL OUTPUT — FORMATTED TRANSCRIPT

$ curl -I http://127.0.0.1:3000
HTTP/1.1 200 OK
Content-Length: 9984

$ curl -s -o /dev/null -w 'HTTP Status: %{http_code}\n' \
  http://127.0.0.1:3000/definitely-not-a-real-path-84729
HTTP Status: 200

$ gobuster dir -u http://127.0.0.1:3000 -w ~/juice-small.txt \
  -s 200,301,302,403,404 -b '' --exclude-length 9984 -t 1 \
  --timeout 20s -o ~/gobuster-status-check.txt

Progress: 200 / 200 (100.00%)
/.well-known/security.txt (Status: 200) [Size: 483]
Note: this is a typeset transcript of recorded results, not a literal screenshot of the terminal.
Finished
```

Recorded output file: ~/gobuster-status-check.txt. Other known local evidence filenames include Gobuster_Small_Scan_Completed.png and Gobuster_Security_Txt_Content.png, but their image files were not available to embed here.

Status-Code Notes: 403 and 404

The assignment note reportedly says “if 403=A, 404=B,” but the available wording does not define what A and B mean. This report therefore does not assign an invented meaning to those labels.

In HTTP terms, 403 generally means the server understood the request but refused access; 404 means the requested resource was not found. In the controlled scan, neither status appeared among the results. This means only that the tested 200-entry wordlist and current configuration did not identify a path returning either status.

Limitations

- The controlled status-code scan covered 200 words, not every possible URL or parameter.
- The application's HTTP 200 fallback behavior complicates enumeration and can create false positives.
- No 403 or 404 results were found in the controlled scan; absence from this output does not prove that such routes do not exist.
- Earlier saved output files contain additional paths, but their exact scan settings and completion state are not fully documented in the preserved notes.
- Only one actual image attachment was available to embed. The terminal evidence shown in Figure 2 is a formatted transcript, not an original screenshot.

Conclusion

The local enumeration exercise demonstrated how Gobuster can discover paths and why response filtering matters when a single-page application returns HTTP 200 for nonexistent URLs. The controlled scan completed all 200 wordlist entries and identified /.well-known/security.txt (200, 483 bytes). No 403 or 404 results were returned in that scan. The next useful improvement is to attach the original terminal screenshots and confirm the instructor's intended definition of "403=A, 404=B" before final submission.